

Day 18: I did good. It answered the question: What is AD actually managing? The next question to answer is "How does an enterprise actually enforce security and configuration across thousands of systems?" The answer to that is: Group Policy.

Day 19 will focus on Group Policy and Enterprise Control. We want to understand: How does a company manage 5,000 computers without touching each one?

Group Policy Foundations

Group Policy is a feature in Microsoft Windows that allows administrators to centrally manage and configure settings for users and computers in a network environment, typically using Microsoft AD. With GP, an admin can: enforce password policies, configure desktop settings, install or remove software, control access to system features (i.e. control panel, usb drives), configure security settings and firewall rules, map network drives and printers, run scripts at startup, shutdown, logon, or logoff.

Group Policy settings are stored in Group Policy Objects (GPOs). These GPOs can be linked to: Sites, Domains, and Organizational Units. When a user logs in or a computer starts, Windows applies the relevant GPOs automatically. To define a GPO: it is a collection of settings that defines how computers and users should be configured in a Windows environment. Group Policy is the overall management system, while GPO is the actual package of rules/settings being applied.

Security Through Group Policy

Password Policies: controls password requirements such as: Minimum password length, password complexity requirements, password history, and maximum password age. Enterprises use it to ensure users create strong passwords that are difficult to guess or crack. Prevents: Password guessing attacks, brute-force attacks, Dictionary attacks, Credential stuffing

Account Lockout Policies: A policy that locks an account after a specified number of failed login attempts. Ex: lock account after 5 failed attempts, locked for 15 mins. Enterprises use it to stop attackers from repeatedly trying passwords against user accounts. Prevents: Brute-force attacks, password spraying attacks

Windows Firewall Policies: configures the Windows Firewall on domain computers. Admins can: allow specific traffic, block unnecessary ports, restrict inbound and outbound connections. Enterprises use it to reduce the attack surface of computers and servers. Prevents: unauthorized remote access, malware communication, lateral movement within a network, exploitation of exposed services

Software Restriction Policies (SRP): controls which programs users are allowed to run. Admins can allow only approved software, block programs from specific locations, restrict unknown executables. Enterprises use it to prevent users from running unauthorized or potentially

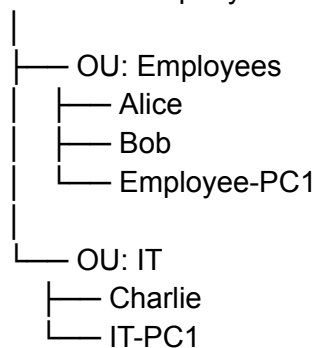
malicious software. Prevents: malware execution, ransomware, unauthorized tools, trojan infections

Powershell Restrictions: limit how powershell can be used. Ex: disable Powershell entirely, restrict script execution, enable powershell logging, force signed scripts only. Prevents: fileless malware attacks, post-exploitation activity, malicious script execution, living-off-the-land attacks

GPO + Active Directory

A GPO is linked to an OU so that the policy automatically applies to all users and computers inside that OU.

Domain: company.com



If an admin creates a GPO called “Employee Security Policy” and links it to the Employee OU, then: Alice, Bob, and Employee-PC1 receives the policy.

Federal Cyber Connection

STIG: Security Technical Implementation Guide. Essentially a security configuration checklist for specific technology